



GROUP 28 · CSIT321

Requirements Traceability Matrix

Certacito.ai · A4 Prototype Presentation appendix

Project Certacito.ai, AI agent governance platform

Document requirements-traceability.md

Date 07 August 2026

Live system <http://20.92.93.30>

Status as of 07 August 2026, against the A2 requirements baseline.

Priority follows MoSCoW. "Evidence" points at where each claim can be verified.

Build order and what depends on what is in the section below the table.

ID	REQUIREMENT	TYPE	PRIORITY	STATUS	EVIDENCE / NOTES
FR-01	Pre-execution interception layer, fail-closed	F	Must	Done	POST /api/v1/intercept (backend/api/interception.py). Engine errors deny; agent-side hook denies if the API is unreachable; no matching rule denies. Agent calls authenticate with X-API-Key.
FR-02	Deterministic policy engine, rules in version-controlled config	F	Must	Done	12 rules in backend/policies.yaml, git-tracked, evaluated in backend/services/policy_engine.py. Conditions are parsed by a recursive-descent parser (backend/services/condition_parser.py) covering ==, !=, >, <, >=, <=, IN, NOT IN, CONTAINS, NOT CONTAINS, MATCHES, NOT MATCHES, AND, OR, NOT and parentheses, with three-valued logic so an unevaluable term is unknown rather than false, resolved against the named sets (approved_tools, restricted_tables, ...) defined in the same file. Those sets were referenced by rules but never actually defined, so every membership test passed and RULE-005 permitted any tool at all - fixed, with regression tests in tests/backend/test_policy_engine.py. Where a condition cannot be resolved the rule does not match and the request falls to the default deny.
FR-03	Immutable audit logging, SHA-256 hash chained	F	Must	Done	backend/services/audit.py. Each entry hashes its own contents plus the previous entry's hash; GET /api/v1/audit/verify walks the whole log from

					genesis, recomputes every hash and reports the first bad entry. It previously only compared stored hashes to each other and never recomputed one, so any column could be edited - a DENY flipped to PERMIT, a Critical dropped to Low - and the chain still reported valid. The hash now covers every stored column (it covered 7 of 12), which changed the recipe, so existing rows were re-chained once via <code>infra/scripts/rechain_audit_v2.py</code> . Tamper tests in <code>tests/backend/test_audit.py</code> . A race that let concurrent appends fork the chain was fixed earlier with an append lock (<code>infra/scripts/repair_audit_chain.py</code>). Append-only is enforced at app level; a DB-level guard (trigger/permissions) is planned for production.
FR-04	RBAC (Administrator/Analyst/Viewer) enforced at the API layer	F	Must	Done	JWT + bcrypt. Every endpoint carries an auth dependency (see README endpoint table). Self-registration disabled: user creation is admin-only, first account bootstraps. Regression tests in <code>tests/backend/test_api.py</code> (RBAC section).
FR-05	Human-in-the-loop approval queue with SLA auto-reject	F	Must	Done (with limitation)	<code>backend/services/approval_service.py</code> . High/Critical escalations pause into the queue; reviewer identity comes from the JWT, not the request body. Limitation: SLA expiry is evaluated lazily when the queue is read, not by a background scheduler - fine while the dashboard polls, a worker task is planned for production.
FR-06	Real-time governance dashboard (<2s to surface	F	Must	Done	WebSocket push (<code>/api/v1/ws/live</code> , JWT-

	events)				authenticated) with a 10s polling fallback. Live feed, KPI tiles, risk donut, top violations. The dashboard socket now authenticates correctly (the deployed build was silently falling back to polling).
FR-07	Secure Azure deployment (CI/CD, Key Vault, TLS 1.3)	NF	Must	Done (with limitation)	Live on an Azure VM in <code>australiaeast</code> (Ubuntu 24.04, <code>Standard_B2ls_v2</code>), Docker Compose: Postgres 16 + Redis 7 + a single app image that serves the API and the built frontend. Deploy is <code>infra/scripts/deploy-vm.sh</code> , triggered over SSH by <code>.github/workflows/deploy.yml</code> ; the CI key is pinned to a forced command so it can only run that script. CI runs on every push and is green. Runbook: <code>docs/azure-deployment.md</code> . Limitation: App Service and Key Vault were dropped in favour of a plain VM (cheaper against student credit, and it hosts the governed agent alongside the platform). Secrets are environment variables in a <code>chmod-600 .env</code> , so a secret manager remains a config change rather than a code change. TLS is terminated by Caddy on the host (<code>infra/caddy/Caddyfile</code>) with a real Let's Encrypt certificate, serving the platform at <code>https://app.20-92-93-30.nip.io</code> . The bare-IP HTTP address still answers because the container publishes port 80 directly, so the plain-HTTP path remains open - a known limitation.
FR-08	Semantic guardrails (prompt-injection detection)	F	Should	Done	<code>backend/services/semantic_guard.py</code> , wired into <code>/intercept</code> and exposed at <code>/guardrails/check</code> . Blocks instruction-override and exfiltration patterns.
FR-09	Risk classification engine (Low/Med/High/Critical)	F	Should	Done	<code>backend/services/risk_classifier.py</code> ,

					/api/v1/risk/classify. High/Critical feeds FR-05 escalation.
FR-10	Policy rule library (5+ pre-built regulated-industry rules)	F	Should	Done (exceeds)	10 rules in backend/rule_library.yml, each tagged with its regulatory alignment (Privacy Act 1988, My Health Records Act, APRA CPS 234, ...). Import via /api/v1/policies/library.
FR-11	Group 2 integration demonstration (GP office agent)	F	Should	Blocked (external)	Waiting on Group 2's agent API contract. The repeatable healthcare scenario (POST /api/v1/demo/healthcare-scenario) demonstrates the same end-to-end flow against simulated GP-office actions in the meantime. Each of its five steps now goes through the same intercept_action() the agents call, so the outcomes come from the policy engine and semantic guard - it previously wrote hardcoded outcomes straight to the audit log, which would have produced the same five results with the engine deleted. The response returns expected vs actual per step.

Build order and dependencies

Nothing here was picked for convenience. Each requirement below could not start until the one above it existed, which is why the Must set closed before any of the Should set opened.

ORDER	REQUIREMENT	DEPENDS ON	WHY IT CANNOT COME EARLIER
1	FR-02 policy engine	none	Every other decision path needs something to ask. Built first against direct calls, no HTTP.
2	FR-03 audit chain	FR-02	There is nothing worth chaining until a decision exists to record.
3	FR-01 interception endpoint	FR-02, FR-03	The endpoint is the seam that joins them. It cannot fail closed until there is an engine to fail

			and a log to record the failure in.
4	FR-04 RBAC	FR-01	Roles are defined per endpoint, so the endpoints have to exist. Agent callers forced the X-API-Key split at this point.
5	FR-09 risk classification	FR-02	Feeds the risk level that FR-05 escalates on.
6	FR-05 approval queue	FR-01, FR-04, FR-09	Needs an ESCALATE outcome to queue, a risk level to trigger on, and a verified reviewer identity to attribute the decision to.
7	FR-06 dashboard	FR-03, FR-05	Reads the audit log and the queue. Nothing to render before both exist.
8	FR-08 semantic guardrails	FR-01	Runs ahead of the policy engine inside the interception path, so it needs that path.
9	FR-10 rule library	FR-02	Pre-built rules are only useful once the engine can evaluate them.
10	FR-07 Azure deployment	FR-01 to FR-06	Deploying an incomplete decision path proves nothing. CI gates the deploy, so the tests had to exist first.
11	FR-11 Group 2 integration	FR-01, FR-07, external	Blocked on a contract we do not own. Not sequencing, a dependency outside the team.

The one true external dependency is FR-11. Everything else is internal sequencing the team controlled.

Changes since A2

- **Added:** agent API-key authentication for machine callers (A2 assumed JWT everywhere; agents cannot do an interactive login).
- **Added:** live traffic simulator for demo/testing (not a requirement, supports FR-06 demonstration).
- **Added:** persistent agent registry (`agents` table). A2 did not call for one; it became necessary once agents had to be suspended and audited by identity.
- **Changed:** FR-07 target is a single Azure VM running Docker Compose, not App Service plus Key Vault. Reason in the FR-07 row. **Azure is the environment A4 demonstrates**, at <https://app.20-92-93-30.nip.io>; Proxmox was development-only and no longer serves the demo.
- **Descoped:** Databricks / Delta Lake migration for the audit store. A2 made this conditional on access being confirmed (Sprint 4, "if access confirmed"). Access was never confirmed, so the audit store stays on PostgreSQL. The hash chain gives the tamper-evidence the migration was wanted for.
- **Removed:** nothing removed from the Must/Should sets.

Non-functional requirements snapshot

NFR	STATUS	NOTES
Fail-closed everywhere	Done	Deny on engine error, on unknown action, on unreachable API, on missing agent key, and on any rule condition that cannot be resolved. The last one was the gap: unresolvable conditions used to be treated as satisfied, which on a <i>permit</i> rule meant allowing the thing the rule was supposed to gate.
PII masking before storage	Done (top-level fields)	Nested payload masking is a known gap, planned before

		production.
Interception latency	Done	Policy evaluation is in-memory; measured well under agent timeout budgets.
WCAG 2.1 AA (risk never colour-only)	Done	Risk badges carry text labels + icons across all screens.
Test coverage	105 tests, all green in CI	Unit (policy, audit, risk, semantic guard) + live integration incl. RBAC regression tests. The integration half skips itself unless the API is up, which in CI meant 27 tests - every RBAC one included - were silently not running and the badge was green off the unit tests alone. CI now starts the API before pytest, so the whole suite runs, and it typechecks the frontend before building rather than only bundling it.